Network Security Concepts

Jean-Michel Dricot – ULB Cybersecurity Research Center

In this lecture...

- Formalizations of “cybersecurity”
- Security objectives
- Threat model
- Network security elements
- Security Mechanisms
- Crypto tools
- Trust model

Cybersecurity

Definition

Collection of tools, policies, security concepts, security safeguards, guidelines, risk management approaches, actions, training, best practices, assurance, and technologies that can be used to **protect** the cyberspace environment and organization and users' assets.

Assets

Organization and users' assets include connected computing **devices, infrastructure**, personnel, applications, services, telecommunications systems, and the totality of transmitted and/or stored **information** in the cyberspace environment

Cybersecurity

- Strives to ensure the attainment and maintenance of the security **properties** of the organization and users' assets against relevant security risks in the cyberspace environment.
- The general security objectives comprise the following:
  - confidentiality
  - integrity
  - availability
  - data authenticity
  - accountability (non repudiation, logging)

Cybersecurity

Information Security

Preservation of confidentiality, integrity, and availability of information. In addition, other properties, such as authenticity, accountability, non-repudiation, and reliability can also be involved

Network Security

Protection of networks and their service from unauthorized modification, destruction, or disclosure, and provision of assurance that the network performs its critical functions correctly and there are no harmful side effects

Security Objectives

Data Confidentiality

Assures that private or confidential information is not made available or disclosed to unauthorized individuals

Privacy

Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed

Security Objectives

Data integrity

Assures that data and programs are changed only in a specified and authorized manner.

This concept also encompasses data authenticity, which means that a digital object is indeed what it claims to be or what it is claimed to be, and non-repudiation, which is assurance that the sender of information is provided with proof of delivery.

Security Objectives

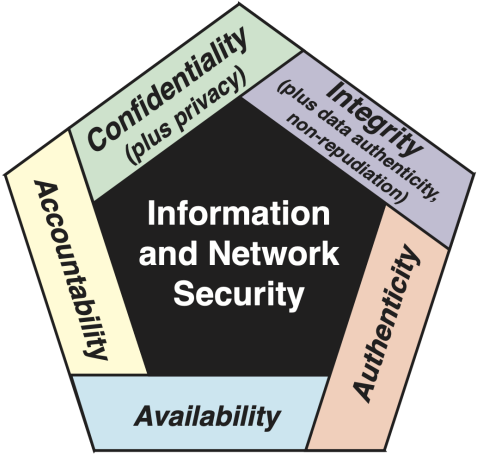
System integrity

Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.

Availability

Assures that systems work promptly and service is not denied to authorized users.

Security Objectives



Security Challenges

- Security is not simple
- Potential attacks on the security features need to be considered
- Procedures used to provide particular services are often counter-intuitive
- Decide where to use the security mechanisms
- Constant monitoring
- Is too often an afterthought
- Typically involve more than a particular algorithm or protocol
- Battle of wits between a perpetrator and the designer
- Little benefit from security investment is perceived until a security failure occurs
- Strong security is often viewed as an impediment to efficient and user-friendly operation

OSI Security Architecture

Security attack

Any action that compromises the security of information owned by an organization

Security mechanism

A process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack

Security service

A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization. Intended to counter security attacks.

Threats and Attacks

Threat

A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm.

Attack

An intelligent act that is a deliberate attempt to evade security services and violate the security policy of a system

Threats and Attacks : Taxonomy

A means of classifying security attacks, used both in X.800 and RFC 4949, is in terms of **passive attacks** and **active attacks**

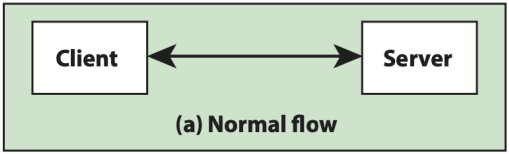
Passive attack

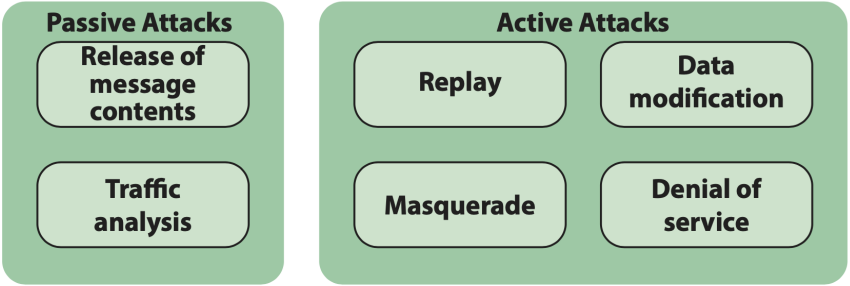
Attempts to learn or make use of information from the system but does not affect system resources

Active attack

Attempts to alter system resources or affect their operation resources

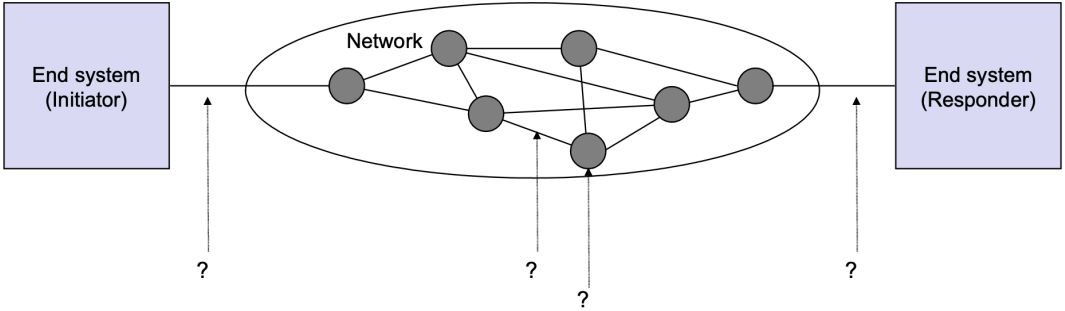
Threats and Attacks : Taxonomy





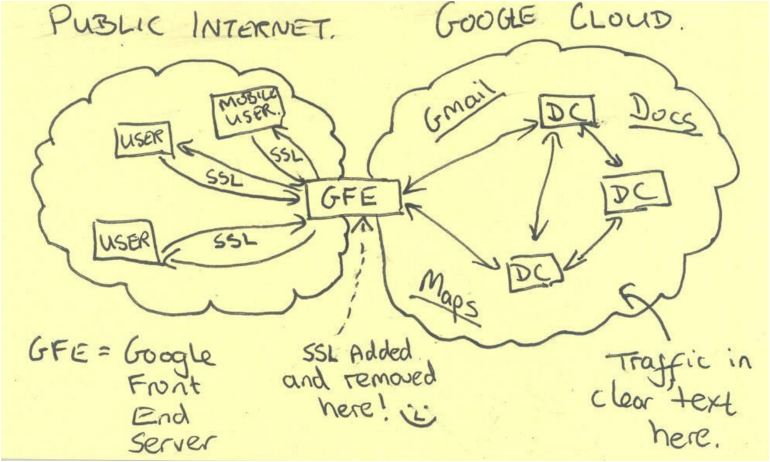
Threats and Attacks : Topology

The attacker's position in the network determines its capabilities



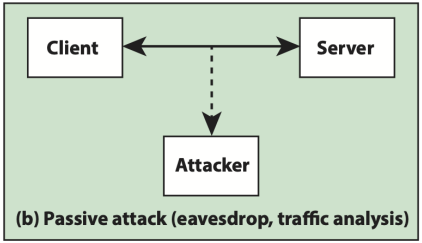
Threats and Attacks : Topology

Source: NSA (Edward Snowden)

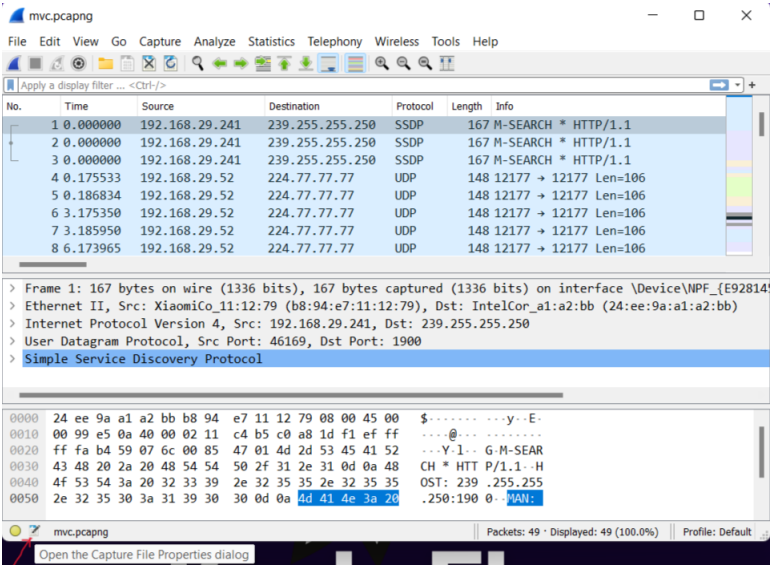


Threats and Attacks : Passive Attacks

- Are in the nature of **eavesdropping** on, or **monitoring** of, transmissions
- Goal of the opponent is to obtain information that is being transmitted
- Two types of passive attacks are:
  - The release of message contents
  - Traffic analysis

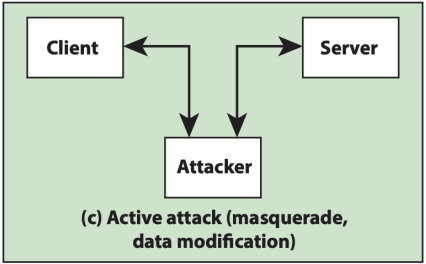


Threats and Attacks : Passive Attacks

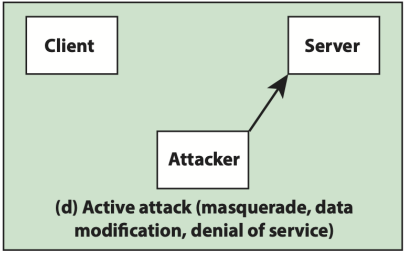


Threats and Attacks : Active Attacks

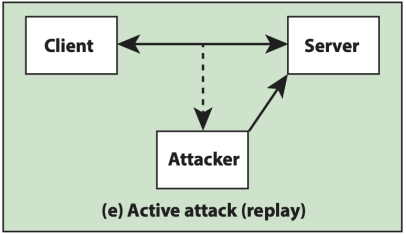
- Involve some **modification** of the data stream or the creation of a false stream
- Difficult to prevent because of the wide variety of potential vulnerabilities
- Goal is to
  - detect attacks
  - recover from any disruption



Threats and Attacks : Active Attacks



(d) Active attack (masquerade, data modification, denial of service)



(e) Active attack (replay)

Threats and Attacks : Active Attacks

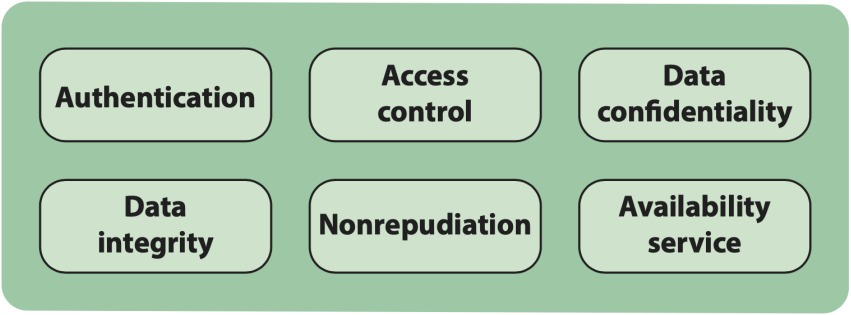
- Masquerade
  - Takes place when one entity pretends to be a different entity
  - Usually includes one of the other forms of active attack
- Replay
  - Involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect
- Data Modification
  - Some portion of a legitimate message is altered, or messages are delayed or reordered to produce an unauthorized effect
- Denial of service
  - Prevents or inhibits the normal use or management of communications facilities

Attacker model for this course

Dolev-Yao attacker model

- The attacker owns the entire the network ("is the network")
- The attacker can perform any active and passive attack
- The attacker has **no** control over end systems
- The attacker **cannot** break cryptographic primitives (encryption, signing, hashing, etc.)

Security Services



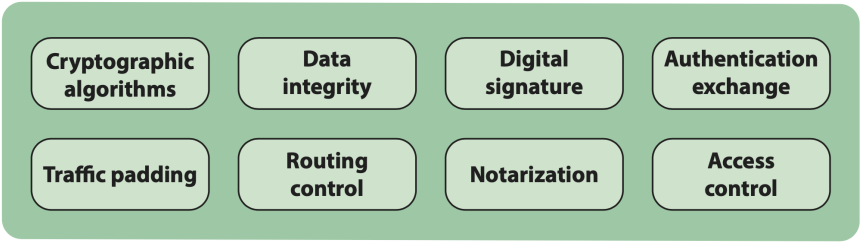
Security Services

- Authentication
  - Assures the recipient that the message is from the source that it claims to be from and that the connection is not interfered with in such a way that a third party can masquerade as one of the two legitimate parties.
  - Two specific authentication services are defined in X.800: (i) peer entity authentication and (ii) data origin authentication.
- Access Control
  - The ability to limit and control the access to host systems and applications via communications links and enforce access rights.
- Data Confidentiality
  - The protection of transmitted data from passive attacks
  - The protection of traffic flow from analysis

Security Services

- Data Integrity
  - Assures that messages are received as sent with no duplication, insertion, modification, reordering, or replays
- Non-repudiation
  - Prevents either sender or receiver from denying a transmitted message
- Availability Service
  - Protects a system to ensure its availability (e.g. denial-of-service attacks)

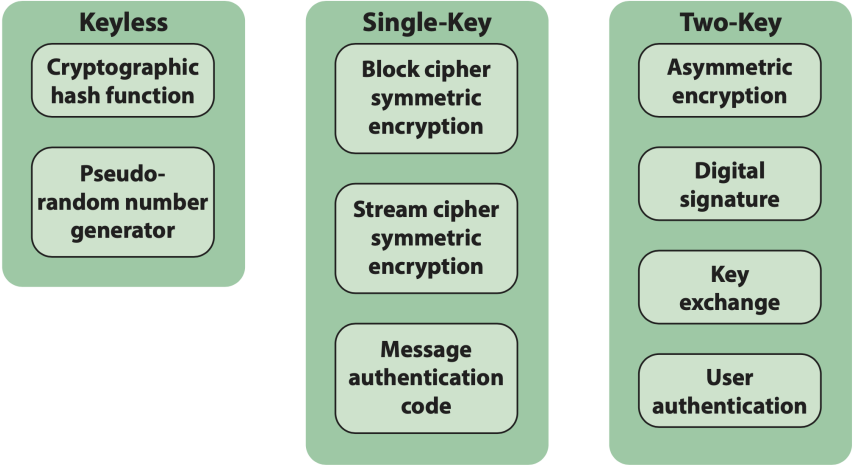
Security Mechanisms



Security Mechanisms

- Digital signature
  - allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery.
- Notarization
  - use of a trusted third party to assure certain properties of a data exchange
- Traffic padding
  - The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.
- Routing control
  - selection of particular physically or logically secure routes for certain data and allows routing changes
- Access control
  - mechanisms that enforce access rights to resources.

Cryptographic Algorithms



Cryptographic Algorithms : Keyless

- Deterministic functions that have certain properties useful for cryptography
- Hash function
  - turns a variable amount of text into a small, fixed-length value called a hash value, hash code, or digest
  - $H(m)$
- Pseudorandom number generator
  - produces a **deterministic** sequence of numbers or bits that has the appearance of being a truly random sequence
  - $PRNG(seed)$

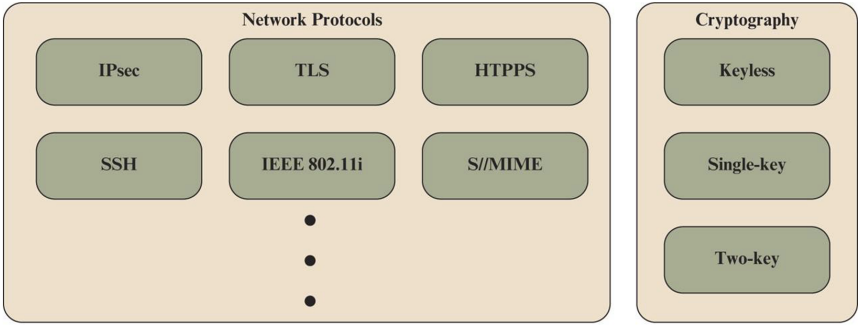
Cryptographic Algorithms : Single-Key

- Encryption algorithms that use a single key (symmetric encryption)
  - Encryption function : $c = Enc(k, m)$ or $c = E(k, m)$
  - Decryption function : $m = Dec(k, c)$ or $m = D(k, c)$
  - Block cipher operates on data as a sequence of blocks
  - Stream cipher operates on data as a sequence of bits
- Message authentication code (MAC)
  - associated with transmitted message
  - designed so that someone in possession of the secret key can verify the integrity of the message
  - $MAC(k, m)$

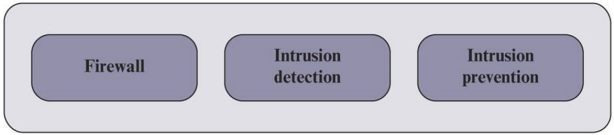
Cryptographic Algorithms : Two Keys

- Asymytric algorithms
  - input some data to be protected and the private key and produces an cipher text
  - corresponding decryption algorithm takes the cipher the corresponding public key and recovers the original data.
  - $c = Enc(k_{pub}, m)$ or $c = E(k_{pub}, m)$
  - $m = Dec(k_{priv}, c)$ or $m = D(k_{priv}, c)$

Key Elements of Network Security



(a) Communications Security



(b) Device Security

Trust Model

Trust

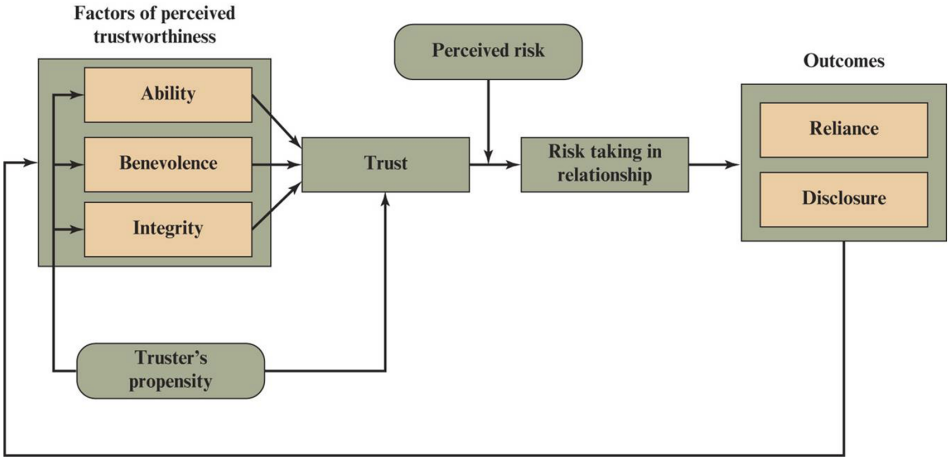
The willingness of a party to be vulnerable to the actions of another party based on the expectation that the other will perform a particular action important to the trustor, irrespective of the ability to monitor or control that other party

Trust Model

Three related concepts are relevant to a trust model:

- **Trustworthiness** : reflects the degree to which that entity is deserving of trust
- **Propensity to trust** : willing to trust others across a broad spectrum of situations and trust targets. This suggests that every individual has some baseline level of trust that will influence it
- **Risk** : A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of
  - the adverse impacts that would arise if the circumstance or event occurs
  - the likelihood of occurrence

Trust Model


Factors of perceived trustworthiness
Ability
Benevolence
Integrity
Perceived risk
Trust
Risk taking in relationship
Outcomes
Reliance
Disclosure
Truster's propensity

Risk Analysis

Impact \ Likelihood	Very unlikely to happen	Unlikely to happen	Possibly could happen	Likely to happen	Very likely to happen
Catastrophic consequences	Moderate	Moderate	High	Critical	Critical
Significant consequences	Low	Moderate	Moderate	High	Critical
Moderate consequences	Low	Moderate	Moderate	Moderate	High
Low consequences	Very Low	Low	Moderate	Moderate	Moderate
Negligible consequences	Very Low	Very Low	Low	Low	Moderate

Risk Analysis

ID	Name	Description	Type (C/I/A)	Cause (A/D)	Impact	Likelihood	Rating	Treatment	Treatment Description
QENT.1	Incorrect data output	Incorrect data could be output from the application and then input into IIQ.	Integrity	Accidental	3	5	15	Reduce	We need to put as many controls in place as we can to reduce the risk of incorrect output data.
QENT.2	Output file tampering	A malicious actor could tamper the output file to add / remove entitlements to his advantage.	Integrity	Deliberate	3	2	6	Transfer	The responsability of the output file is set to the person that created it (authentication = only allowed people
QENT.3	Output file data leak	A malicious actor could read the data from the output file to gain access to information he shouldn't have.	Confidentiality	Deliberate	2	2	4	Transfer	The responsability of the output file is set to the person that created it (authentication = only allowed people
QENT.4	Application unauthorized access (Write)	A malicious actor could access the application to modify entitlements.	Integrity	Deliberate	3	2	6	Mitigate	Access control must be implemented in the application and only a limited number of employees should have
QENT.5	Application unauthorized access (Read)	A malicious actor could access the application to see entitlements he shouldn't have access to.	Confidentiality	Deliberate	2	2	4	Mitigate	Access control must be implemented in the application and only a limited number of employees should have
QENT.6	Incorrect data from data source	Incorrect data could be present in one of the data sources of the application, thus reducing the quality of the output.	Integrity	Accidental	2	4	8	Accept	We have no way of controlling the validity of the data from the sources, we therefore have to assume the data
QENT.7	Outdated data source	One of the data sources is not updated and the application will therefore not be usable (because of the	Availibility	Accidental	1	3	3	Accept	Display to the user which data source is out of date and who to contact to complain.
QENT.8	Cross-environment data pollution (NPRD to PRD)	Data from a non PRD environment could end up being written in PRD.	Integrity	Accidental	3	3	9	Mitigate	Put controls in place to prevent cross-environment data movement.
QENT.9	Cross-environment data pollution (PRD to NPRD)	Data from PRD could be written to a non PRD environment.	Confidentiality	Accidental	1	3	3	Mitigate	Put controls in place to prevent cross-environment data movement.
QENT.10	Data override	The application could override already present data	Integrity	Accidental	2	3	6	Mitigate	Put controls in place to prevent data override (IIQ export must be very recent, ...)

Likelyhood \ Impact	1	2	3	4	5
1	1	2	3	4	5
2	2	4	6	8	10
3	3	6	9	12	15
4	4	8	12	16	20
5	5	10	15	20	25

Likelyhood	Weight	Description
Rare	1	Once every 10 years
Unlikely	2	Every 7 - 9 years
Possible	3	Every 4 - 6 years
Likely	4	Every 2-3 years
Highly likely	5	In the following year

Impact	Weight
Very low	1
Low	2
Medium	3
High	4
Very high	5

Trust Relationships

- **Validated trust**
  - Trust is based on evidence obtained by the trusting organization about the trusted organization or entity. The information may include information security policy, security measures, and level of oversight
- **Direct historical trust**
  - This type of trust is based on the security-related track record exhibited by an organization in the past, particularly in interactions with the organization seeking to establish trust
- **Mediated trust**
  - Mediated trust involves the use of a third party that is mutually trusted by two parties, with the third party providing assurance or guarantee of a given level of trust between the first two parties
- **Mandated trust**
  - An organization establishes a level of trust with another organization based on a specific mandate issued by a third party in a position of authority